

Boulangerie Martin (exemple fictif)

Site contrôlé : <https://boulangerie-martin.example/> · Rapport du 3 octobre 2026 · Outil d'audit v1.0

2

à corriger

3

à améliorer

1

à savoir

4

conformes

Résultats

HTTPS et certificat

Conforme

HTTPS actif avec un certificat valide.

- Émetteur : autorité de certification reconnue · valide jusqu'au 12 janvier 2027 (101 jours)
- La version http redirige bien vers https.

En-têtes de sécurité

À améliorer

3 en-têtes de sécurité absents sur 5.

- Présent : HSTS (force HTTPS)
- Présent : X-Content-Type-Options
- Absent : Politique de sécurité de contenu (CSP) · Referrer-Policy · Protection contre le clickjacking (X-Frame-Options ou frame-ancestors)

Que faire : À régler chez l'hébergeur ou le serveur quand c'est possible. Certains hébergements gratuits (comme GitHub Pages) ne permettent pas de les modifier : ce point est alors indicatif.

Services externes chargés

À améliorer

1 script(s) ou feuille(s) de style et 1 police(s) viennent d'un service externe.

- script chargé depuis cdn.exemple-scripts.net (sans vérification d'intégrité)
- police chargée depuis fonts.gstatic.com : l'adresse IP des visiteurs lui est transmise

Que faire : Héberger ces fichiers sur le site, ou ajouter une vérification d'intégrité (attribut integrity) et une version fixe. Une police externe transmet l'adresse IP du visiteur : à signaler dans la politique de confidentialité ou à héberger soi-même.

Cookies et traceurs dès l'arrivée

À corriger

Des services de mesure ou de publicité sont contactés avant tout consentement.

- Service de mesure ou de publicité contacté dès l'arrivée : `www.googletagmanager.com`
- Cookie posé dès l'arrivée : `_ga` (boulangerie-martin.example, 400 jours)

Que faire : Les cookies strictement nécessaires peuvent être exemptés, pas la mesure d'audience ni la publicité : prévoir un bandeau de consentement ou retirer ces services. Ce contrôle constate des faits ; la conformité juridique est à valider par un professionnel.

Formulaires

À améliorer

1 formulaire(s) trouvé(s) sur la page d'accueil.

- Formulaire 1 : envoi chiffré vers `boulangerie-martin.example`
- Formulaire 1 : aucun anti-spam visible (champ piège ou captcha)

Que faire : Envoyer les formulaires en `https` et ajouter un anti-spam (champ piège, captcha respectueux de la vie privée).

Contenu mixte, liens et erreurs

Conforme

Pas de contenu mixte, liens protégés, console sans erreur.

Pages obligatoires (présence uniquement)

À savoir

Pages non repérées : Cookies.

- Lien trouvé : Mentions légales
- Lien trouvé : Politique de confidentialité
- Aucun lien trouvé : Cookies
- Lien trouvé : Conditions générales de vente

Que faire : Selon l'activité du site, certaines de ces pages sont obligatoires (la boutique en ligne doit avoir des CGV, par exemple). L'audit vérifie seulement que les liens existent, pas leur contenu ni leur conformité.

Bibliothèques et outils détectés

À corriger

Des bibliothèques anciennes, connues pour des failles, sont utilisées.

- jQuery 3.3.1 : version antérieure à 3.5.0, connue pour des failles XSS (CVE-2020-11022 et 11023)

Que faire : Mettre à jour ces bibliothèques. Ce contrôle repose sur mes connaissances des failles publiées, pas sur une base consultée en direct : il ne peut pas être exhaustif.

Clés oubliées dans le code public

Conforme

Aucune clé connue trouvée (4 fichiers lus).

Fichiers sensibles exposés

Conforme

Aucun des 11 fichiers sensibles courants n'est accessible.

- Fichiers testés : /.env, /.git/HEAD, /.git/config, /.DS_Store, /wp-config.php.bak, /wp-config.php~, /phpinfo.php, /backup.zip, /backup.sql, /database.sql, /config.json

Ce que cet audit ne couvre pas

Cet audit ne contrôle que ce qui est visible de l'extérieur sur la page d'accueil. Il ne couvre pas :

- Le serveur et l'hébergement en interne, la configuration du réseau.
- Les mots de passe, les droits d'accès, les comptes administrateur.
- Les sauvegardes et la reprise après incident.
- Les réglages dans des consoles auxquelles l'audit n'a pas accès (Google, Firebase, Shopify, PayPal, hébergeur...).
- La conformité juridique (RGPD, mentions légales, CGV) : seule la présence des pages est constatée.
- Les failles propres au fonctionnement du site (logique métier, droits entre utilisateurs), qui demandent un vrai test d'intrusion.
- Les pages autres que l'accueil, sauf mention contraire.

Portée. Ce rapport décrit l'état constaté des points listés à la date indiquée. Il ne constitue ni une certification, ni un test d'intrusion, ni un avis juridique, et ne garantit pas que le site est sécurisé. Contrôle réalisé avec l'accord écrit du propriétaire du site.